TECHNICAL DETAIL

Title	Critical Sensitive Information Disclosure via Publicly Accessible .env
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-21
Affected Asset	https://pegawai.my.id/.env
Severity	High
CVSS Score	7.5 CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

Ditemukan kesalahan konfigurasi server (*Security Misconfiguration*) yang kritikal pada situs pegawai.my.id di mana berkas konfigurasi lingkungan Laravel (.env) dapat diakses dan diunduh secara terbuka oleh publik tanpa memerlukan autentikasi. Berkas tersebut mengandung informasi kredensial yang sangat sensitif, termasuk kunci enkripsi aplikasi (*APP_KEY*), kredensial basis data (*DB_PASSWORD*), hingga detail teknis infrastruktur seperti alamat IP lokal dan status *debug* aplikasi. Keterbukaan informasi ini memungkinkan penyerang anonim untuk membaca seluruh konfigurasi dalam format teks polos, yang berpotensi menyebabkan pencurian data massal atau pengambilalihan akun secara menyeluruh.

STEPS TO REPRODUCE

1. Buka cmd lalu ketik dirsearch -u "https://pegawai.my.id/" maka terlihat file .env yang bocor

```
┌──(nectar㉿nectar)-[~]
└─$ dirsearch -u "https://pegawai.my.id/"
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https:/
/setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ |_    v0.4.3
 (_|| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460

Output File: /home/nectar/reports/https_pegawai.my.id/__25-12-24_01-47-03.txt

Target: https://pegawai.my.id/

[01:47:03] Starting:
[01:47:06] 200 -   10KB - /.DS_Store
[01:47:07] 200 -    1KB - /.env
```

2. Buka https://pegawai.my.id/.env maka file env akan terunduh

```
APP_NAME=Laravel
APP_ENV=local
APP_KEY=base64:GIkdIyWENkeWtwavSf6YUHvuGoxSr72CvfKpgYBGV+0=
APP_DEBUG=true
APP_TIMEZONE=UTC
APP_URL=https://pegawai.my.id

APP_LOCALE=en
APP_FALLBACK_LOCALE=en
APP_FAKER_LOCALE=en_US

APP_MAINTENANCE_DRIVER=file
# APP_MAINTENANCE_STORE=database

PHP_CLI_SERVER_WORKERS=4

BCRYPT_ROUNDS=12

LOG_CHANNEL=stack
LOG_STACK=single
LOG_DEPRECATIONS_CHANNEL=null
LOG_LEVEL=debug

DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=pegawai
DB_USERNAME=pegawai
DB_PASSWORD=passwordaman123

SESSION_DRIVER=database
SESSION_LIFETIME=120
SESSION_ENCRYPT=false
SESSION_PATH=/
SESSION_DOMAIN=null

BROADCAST_CONNECTION=log
FILESYSTEM_DISK=local
QUEUE_CONNECTION=database

CACHE_STORE=database
CACHE_PREFIX=

MEMCACHED_HOST=127.0.0.1

REDIS_CLIENT=phpredis
REDIS_HOST=127.0.0.1
REDIS_PASSWORD=null
REDIS_PORT=6379

MAIL_MAILER=log
MAIL_SCHEME=null
MAIL_HOST=127.0.0.1
MAIL_PORT=2525
MAIL_USERNAME=null
MAIL_PASSWORD=null
MAIL_FROM_ADDRESS="hello@example.com"
MAIL_FROM_NAME="${APP_NAME}"
```

```
AWS_ACCESS_KEY_ID=
AWS_SECRET_ACCESS_KEY=
AWS_DEFAULT_REGION=us-east-1
AWS_BUCKET=
AWS_USE_PATH_STYLE_ENDPOINT=false

VITE_APP_NAME="${APP_NAME}"
```

EXPECTED RESULT

Seharusnya, server web (Nginx/Apache) dikonfigurasi untuk menolak semua akses publik ke file sensitif atau file tersembunyi yang diawali dengan titik (seperti .env, .git, .config). Pengguna yang mencoba mengakses URL tersebut seharusnya mendapatkan respons HTTP 403 Forbidden atau 404 Not Found.

ACTUAL RESULT

File .env dapat diakses sepenuhnya oleh pengguna anonim tanpa harus login (status HTTP 200 OK). Penyerang dapat membaca seluruh isi konfigurasi aplikasi dalam format teks polos (*cleartext).*

IMPACT

1. Kehilangan Kerahasiaan Data (Confidentiality Loss): Penyerang mendapatkan akses ke kredensial database (passwordaman123), yang berpotensi menyebabkan pencurian seluruh data karyawan dan perusahaan.
2. Risiko Pengambilalihan Akun: Dengan APP_KEY yang bocor, penyerang yang ahli dapat mendekripsi cookie sesi pengguna dan memalsukan identitas untuk masuk sebagai pengguna lain atau administrator (*Account Takeover*).
3. Eksposur Informasi Infrastruktur: Penyerang mengetahui detail teknis server seperti alamat IP lokal (127.0.0.1), driver sesi (database), dan status debug aplikasi.

RECOMMENDATION

1. Konfigurasi Web Server: Tambahkan aturan pada konfigurasi server (Nginx/Apache) untuk memblokir akses ke semua file yang diawali dengan titik (.*).
2. Rotasi Kredensial (Wajib): Segera ganti Password Database dan buat ulang APP_KEY (php artisan key:generate) karena kunci yang lama sudah dianggap kompromi (tidak aman).
3. Nonaktifkan Debug Mode: Ubah pengaturan menjadi APP_DEBUG=false di lingkungan produksi (*production environment*) untuk mencegah kebocoran informasi teknis.

REFERENCES

1. OWASP Top 10 - A05:2021 Security Misconfiguration: https://owasp.org/Top10/A05_2021-Security_Misconfiguration/
2. CWE-200: Exposure of Sensitive Information to an Unauthorized Actor: https://cwe.mitre.org/data/definitions/200.html
3. Laravel Documentation - Deployment & Environment Configuration: https://laravel.com/docs/10.x/deployment#server-configuration